ZAP by Checkmarx Scanning Report

Sites: https://fastapi.tiangolo.com https://cdn.jsdelivr.net https://localhost:8080

Generated on qua., 21 out. 2026 20:36:05

ZAP Version: 2.17.0

ZAP by Checkmarx

Summary of Alerts

Nível de Risco	Number of Alerts
Alto	0
Médio	5
Baixo	2
Informativo	5

Insights

Level	Reason	Site	Description	Statistic
Info	Informational	https://cdn.jsdelivr.net	Percentage of responses with status code 2xx	100 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with content type application/javascript	50 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with content type text/css	50 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with method GET	100 %
Info	Informational	https://cdn.jsdelivr.net	Count of total endpoints	2

Info	Informational	https://cdn.jsdelivr.net	Percentage of slow responses	100 %
Info	Informational	https://fastapi.tiangolo.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://fastapi.tiangolo.com	Percentage of endpoints with content type image/png	100 %
Info	Informational	https://fastapi.tiangolo.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://fastapi.tiangolo.com	Count of total endpoints	1
Info	Informational	https://fastapi.tiangolo.com	Percentage of slow responses	25 %
Info	Informational	https://localhost:8080	Percentage of responses with status code 2xx	100 %
Info	Informational	https://localhost:8080	Percentage of endpoints with content type application/json	75 %
Info	Informational	https://localhost:8080	Percentage of endpoints with content type text/html	25 %
Info	Informational	https://localhost:8080	Percentage of endpoints with method GET	50 %
Info	Informational	https://localhost:8080	Percentage of endpoints with method POST	50 %
Info	Informational	https://localhost:8080	Count of total endpoints	4

Info	Informational	https://localhost:8080	Percentage of slow responses	18 %

Alertas

Nome	Nível de Risco	Number of Instances
CSP: Failure to Define Directive with No Fallback	Médio	1
CSP: script-src unsafe-inline	Médio	1
CSP: style-src unsafe-inline	Médio	1
Configuração Incorreta Entre Domínios	Médio	4
Sub Resource Integrity Attribute Missing	Médio	2
Cross-Domain JavaScript Source File Inclusion	Baixo	1
Divulgação de Data e Hora - Unix	Baixo	Systemic
Divulgação de Informações - Comentários Suspeitos	Informativo	1
Modern Web Application	Informativo	1
Re-examine Cache-control Directives	Informativo	2
Retrieved from Cache	Informativo	2
Solicitação de autenticação identificada	Informativo	2

Alert Detail

Médio	CSP: Failure to Define Directive with No Fallback
Descrição	The Content Security Policy fails to define one of the directives that has no fallback. Missing /excluding them is the same as allowing anything.
URL	https://localhost:8080/docs
Node Name	https://localhost:8080/docs
Método	GET
Ataque	
Evidence	default-src 'self'; script-src 'self' https://cdn.jsdelivr.net 'unsafe-inline'; style-src 'self' https://cdn.jsdelivr.net 'unsafe-inline'; img-src 'self' data: https://fastapi.tiangolo.com; font-src 'self' https://cdn.jsdelivr.net; connect-src 'self' https://cdn.jsdelivr.net;
Other Info	The directive(s): frame-ancestors, form-action is/are among the directives that do not fallback to default-src.
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Médio	CSP: script-src unsafe-inline
Descrição	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://localhost:8080/docs
Node Name	https://localhost:8080/docs
Método	GET
Ataque	
Evidence	default-src 'self'; script-src 'self' https://cdn.jsdelivr.net 'unsafe-inline'; style-src 'self' https://cdn.jsdelivr.net 'unsafe-inline'; img-src 'self' data: https://fastapi.tiangolo.com; font-src 'self' https://cdn.jsdelivr.net; connect-src 'self' https://cdn.jsdelivr.net;
Other Info	script-src includes unsafe-inline.
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Médio	CSP: style-src unsafe-inline
Descrição	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://localhost:8080/docs
Node Name	https://localhost:8080/docs
Método	GET
Ataque	
Evidence	default-src 'self'; script-src 'self' https://cdn.jsdelivr.net 'unsafe-inline'; style-src 'self' https://cdn.jsdelivr.net 'unsafe-inline'; img-src 'self' data: https://fastapi.tiangolo.com; font-src 'self' https://cdn.jsdelivr.net; connect-src 'self' https://cdn.jsdelivr.net;
Other Info	style-src includes unsafe-inline.
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy

Reference	https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Médio	Configuração Incorreta Entre Domínios
Descrição	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Método	GET
Ataque	
Evidence	Access-Control-Allow-Origin: *
Other Info	A configuração incorreta do CORS no servidor da web permite solicitações de leitura entre domínios de domínios arbitrários de terceiros, usando APIs não autenticadas neste domínio. No entanto, as implementações do navegador da Web não permitem que terceiros arbitrários leiam a resposta de APIs autenticadas. Isso reduz o risco um pouco. Essa configuração incorreta pode ser usada por um invasor para acessar dados que estão disponíveis de maneira não autenticada, mas que usam alguma outra forma de segurança, como lista de permissões de endereços IP.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Método	GET
Ataque	
Evidence	access-control-allow-origin: *
Other Info	A configuração incorreta do CORS no servidor da web permite solicitações de leitura entre domínios de domínios arbitrários de terceiros, usando APIs não autenticadas neste domínio. No entanto, as implementações do navegador da Web não permitem que terceiros arbitrários leiam a resposta de APIs autenticadas. Isso reduz o risco um pouco. Essa configuração incorreta pode ser usada por um invasor para acessar dados que estão disponíveis de maneira não autenticada, mas que usam alguma outra forma de segurança, como lista de permissões de endereços IP.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui.css
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui.css
Método	GET
Ataque	
Evidence	Access-Control-Allow-Origin: *
Other Info	A configuração incorreta do CORS no servidor da web permite solicitações de leitura entre domínios de domínios arbitrários de terceiros, usando APIs não autenticadas neste domínio. No entanto, as implementações do navegador da Web não permitem que terceiros arbitrários leiam a resposta de APIs autenticadas. Isso reduz o risco um pouco. Essa configuração incorreta pode ser usada por um invasor para acessar dados que estão disponíveis de maneira não autenticada, mas que usam alguma outra forma de segurança, como lista de permissões de endereços IP.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui.css
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui.css

Método	GET
Ataque	
Evidence	access-control-allow-origin: *
Other Info	A configuração incorreta do CORS no servidor da web permite solicitações de leitura entre domínios de domínios arbitrários de terceiros, usando APIs não autenticadas neste domínio. No entanto, as implementações do navegador da Web não permitem que terceiros arbitrários leiam a resposta de APIs autenticadas. Isso reduz o risco um pouco. Essa configuração incorreta pode ser usada por um invasor para acessar dados que estão disponíveis de maneira não autenticada, mas que usam alguma outra forma de segurança, como lista de permissões de endereços IP.
Instances	4
Solution	Certifique-se de que dados confidenciais não estejam disponíveis de maneira não autenticada (usando uma lista branca/de permissões de endereços IP, por exemplo). Configure o cabeçalho HTTP "Access-Control-Allow-Origin" para um conjunto mais restritivo de domínios ou remova todos os cabeçalhos CORS inteiramente, para permitir que o navegador web aplique a Same Origin Policy (SOP) de uma maneira mais restritiva.
Reference	https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
CWE Id	264
WASC Id	14
Plugin Id	10098

Médio	**Sub Resource Integrity Attribute Missing**
Descrição	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
URL	https://localhost:8080/docs
Node Name	https://localhost:8080/docs
Método	GET
Ataque	
Evidence	<link type="text/css" rel="stylesheet" href="https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui.css">
Other Info	
URL	https://localhost:8080/docs
Node Name	https://localhost:8080/docs
Método	GET
Ataque	
Evidence	<script src="https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js"></script>
Other Info	
Instances	2
Solution	Provide a valid integrity attribute to the tag.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003

Baixo	Cross-Domain JavaScript Source File Inclusion
Descrição	The page includes one or more script files from a third-party domain.
URL	https://localhost:8080/docs
Node Name	https://localhost:8080/docs
Método	GET
Ataque	
Evidence	<script src="https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js"></script>
Other Info	
Instances	1
Solution	Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.
Reference	
CWE Id	829
WASC Id	15
Plugin Id	10017

Baixo	Divulgação de Data e Hora - Unix
Descrição	A timestamp was disclosed by the application/web server. - Unix
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Método	GET
Ataque	
Evidence	1518500249
Other Info	1518500249, which evaluates to: 2018-02-13 03:37:29.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Método	GET
Ataque	
Evidence	1732584193
Other Info	1732584193, which evaluates to: 2024-11-25 22:23:13.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Método	GET
Ataque	
Evidence	1750603025
Other Info	1750603025, which evaluates to: 2025-06-22 11:37:05.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Node	

Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Método	GET
Ataque	
Evidence	1859775393
Other Info	1859775393, which evaluates to: 2028-12-07 01:16:33.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Método	GET
Ataque	
Evidence	1894007588
Other Info	1894007588, which evaluates to: 2030-01-07 06:13:08.
Instances	Systemic
Solution	Confirme manualmente se os dados do carimbo de data/hora não são confidenciais e se os dados não podem ser agregados para divulgar padrões exploráveis.
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Informativo	**Divulgação de Informações - Comentários Suspeitos**
Descrição	The response appears to contain suspicious comments which may help an attacker.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Método	GET
Ataque	
Evidence	query
Other Info	The following pattern was used: \bQUERY\b and was detected in likely comment: "//","$"), z=COMMENT("/*","*/"),U=COMMENT("#","$"),Y={className:"number",begin:w, relevance:0},Z={className:"number",begin:x,re", see evidence field for the suspicious comment/snippet.
Instances	1
Solution	Remova todos os comentários que retornam informações que podem ajudar um invasor e corrigir quaisquer problemas subjacentes aos quais eles se referem.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informativo	**Modern Web Application**
Descrição	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	https://localhost:8080/docs
Node	

Name	https://localhost:8080/docs
Método	GET
Ataque	
Evidence	<script src="https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	1
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informativo	**Re-examine Cache-control Directives**
Descrição	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
URL	https://localhost:8080/docs
Node Name	https://localhost:8080/docs
Método	GET
Ataque	
Evidence	
Other Info	
URL	https://localhost:8080/openapi.json
Node Name	https://localhost:8080/openapi.json
Método	GET
Ataque	
Evidence	
Other Info	
Instances	2
Solution	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/
CWE Id	525
WASC Id	13
Plugin Id	10015

Informativo	**Retrieved from Cache**
	The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this

Descrição	may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Método	GET
Ataque	
Evidence	HIT
Other Info	
URL	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui.css
Node Name	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui.css
Método	GET
Ataque	
Evidence	HIT
Other Info	
Instances	2
Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.rfc-editor.org/rfc/rfc9110.html
CWE Id	525
WASC Id	
Plugin Id	10050

Informativo	**Solicitação de autenticação identificada**
Descrição	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	https://localhost:8080/auth/token
Node Name	https://localhost:8080/auth/token ()(grant_type,password,username)
Método	POST
Ataque	

Evidence	password
Other Info	userParam=username userValue=admin passwordParam=password referer=https://localhost:8080/docs
URL	https://localhost:8080/auth/signin
Node Name	https://localhost:8080/auth/signin ()({login,password})
Método	POST
Ataque	
Evidence	password
Other Info	userParam=login userValue=admin passwordParam=password referer=https://localhost:8080/docs
Instances	2
Solution	Este é um alerta informativo e não uma vulnerabilidade, portanto não há nada a ser corrigido.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111